

Servizio di Verifica Anti-Truffa

Controllo di affidabilit  di siti web e aziende – documento di progettazione funzionale e tecnica per il team di implementazione

Ambito: nuovo servizio da integrare nella suite di servizi gi  esistente.

Obiettivo del documento: fornire al team incaricato dell'implementazione tutte le nozioni funzionali, le fonti dati e l'architettura consigliata per realizzare lo strumento, senza vincolare fin da subito a una specifica implementazione di codice.

Documento generato con il supporto di Claude – settembre 2026

1. Obiettivo del servizio

Il servizio permette a un utente di inserire un URL o i dati di un'azienda (nome, Partita IVA) e ricevere un report di affidabilità basato su controlli automatici incrociati su più fonti pubbliche e commerciali. Non fornisce un verdetto assoluto ("sicuro" / "truffa"), ma un **punteggio di rischio** con il dettaglio dei singoli controlli, così da supportare la decisione dell'utente e restare legalmente difendibile.

2. Le due dimensioni della verifica

Sono due controlli concettualmente distinti, che un buon tool esegue entrambi e poi incrocia tra loro (es. il sito dichiara l'azienda X ma l'azienda X non risulta in Camera di Commercio → segnale di rischio forte).

- **Verifica del sito web** (dominio/URL): è un sito legittimo o una possibile truffa/phishing?
- **Verifica dell'azienda** (ragione sociale, P.IVA): l'entità dietro il sito esiste realmente ed è attiva?

3. Controlli tecnici sul sito web

Controllo	Cosa rivela	Fonte / API
WHOIS	Data registrazione dominio, registrar, privacy proxy attivo	whoisjson.com, whoisxmlapi, libreria whois diretta
Eta dominio	Domini creati da pochi giorni/settimane sono un forte indicatore di truffa	WHOIS + Wayback Machine API (gratuita)
Certificato SSL	Validità, autorità emittente, se e troppo recente	SSL Labs API (gratuita)
DNS / email aziendale	Presenza di record SPF/DKIM/DMARC coerenti (le aziende serie li configurano)	Query DNS dirette
Reputazione / malware	Il dominio è già segnalato come phishing o malware	Google Safe Browsing, VirusTotal, PhishTank, URLhaus (abuse.ch) – tutte gratuite con rate limit
Typosquatting	Il dominio imita un brand noto (es. amaz0n-shop.com)	Distanza di Levenshtein contro una lista di brand noti
Hosting / IP	Paese di hosting sospetto, hosting condiviso con altri domini malevoli	GeoIP (MaxMind), reverse IP lookup
Contenuto pagina	Presenza di P.IVA, indirizzo fisico, privacy policy e T&C reali (non placeholder)	Scraping + parsing testuale
Social proof	Presenza social coerente, recensioni reali	Trustpilot API, Google Places API

4. Controlli sull'azienda

Controllo	Cosa rivela	Fonte / API
Partita IVA UE	Se la P.IVA è valida e attiva	VIES – ufficiale UE, gratuita
Registro Imprese IT	Stato (attiva / cessata / fallita), sede legale, data costituzione	Infocamere / Telemaco (a pagamento) o servizi terzi
PEC	Se l'email certificata dichiarata esiste davvero	INI-PEC (registro pubblico)
Aziende estere	Database globale delle società	OpenCorporates API (freemium)
Liste sanzioni	L'entità compare in liste per sanzioni o frodi	OFAC SDN list, lista sanzioni UE (gratuite, aggiornate periodicamente)

5. Sistema di punteggio (scoring)

Evitare un verdetto binario (“sicuro / truffa”): è legalmente rischioso e spesso impreciso. Meglio un **punteggio di affidabilità da 0 a 100** con badge colorato:

- **Verde (80–100):** nessun segnale di rischio rilevato
- **Giallo (40–79):** alcuni elementi da verificare manualmente
- **Rosso (0–39):** presenti segnali multipli di rischio

Ogni controllo contribuisce con un peso al punteggio finale (esempio indicativo): dominio registrato da meno di 30 giorni → -25 punti; presenza in blacklist malware → -40 punti; P.IVA non valida → -30 punti; SSL assente o non valido → -15 punti.

Importante: mostrare sempre il dettaglio dei singoli controlli, non solo il numero finale. E ciò che dà valore percepito al report ed è più difendibile dal punto di vista legale rispetto a un giudizio secco.

6. Architettura tecnica consigliata

Flusso logico del sistema:

- **Frontend:** form di input (URL oppure P.IVA/ragione sociale) con rilevamento automatico del tipo di ricerca
- **Backend orchestratore:** chiama in parallelo le API esterne (non in sequenza, per non far attendere l'utente 10+ secondi)
- **Timeout per singolo controllo:** se un'API è lenta o non risponde, il report prosegue comunque con gli altri controlli
- **Cache dei risultati** (es. Redis, TTL 24–48 ore): i dati WHOIS o di registro non cambiano ogni minuto, evita di consumare quote API a pagamento
- **Rate limiting sull'utente finale:** per evitare abusi delle chiavi API del servizio
- **Calcolo dello score aggregato** a valle di tutti i controlli
- **Storage dello storico ricerche** (opzionale, per utenti loggati)

Nota UX/performance: il rendering dei risultati dovrebbe essere progressivo (mostrare ogni controllo man mano che arriva la risposta), non un unico blocco alla fine dell'elaborazione.

7. Flusso utente (UX)

- Campo di input unico (URL o nome azienda/P.IVA) con auto-detect del tipo di ricerca
- Stato di caricamento con elenco dei controlli in corso di esecuzione (percezione di analisi approfondita)
- Risultato: badge grande con punteggio, seguito da sezioni espandibili per categoria (Dominio, Sicurezza, Azienda, Reputazione)
- Ogni voce con icona di stato (ok / attenzione / rischio) e spiegazione in linguaggio semplice, non tecnico
- Opzione di esportazione del report in PDF (utile per un eventuale livello premium del servizio)
- Call to action finale con link alle fonti ufficiali per approfondire (es. link diretto a VIES, Registro Imprese)

8. Aspetti legali e limiti da non trascurare

- **Disclaimer obbligatorio:** il servizio non costituisce consulenza legale o finanziaria, ma uno strumento informativo a supporto della decisione
- **Privacy/GDPR:** se si registrano le ricerche effettuate dagli utenti, va fornita un'informativa privacy e valutata l'anonimizzazione dei dati
- **Costi API:** alcune fonti (es. Registro Imprese italiano) sono a pagamento per uso commerciale – pianificare i costi in base al volume atteso di ricerche
- **Evitare giudizi assoluti** del tipo “sito sicuro al 100%”: espone a responsabilità legale in caso di errore

9. Roadmap: MVP vs versione avanzata

MVP (realizzabile in tempi brevi, quasi interamente con fonti gratuite):

WHOIS + eta dominio + controllo SSL + Google Safe Browsing + VIES per la P.IVA. Questo set copre già circa l'80% dei casi di truffa evidente.

Versione avanzata:

Integrazione completa con il Registro Imprese, OpenCorporates, analisi del contenuto della pagina con NLP, rilevamento typosquatting, storico tramite Wayback Machine, integrazione recensioni (Trustpilot / Google).

Documento a uso interno per la pianificazione del nuovo servizio. Da integrare con requisiti tecnici specifici (stack, budget API, volumi attesi) prima della fase di implementazione.